

[doc. web n. 10008177]
Provision of March 7, 2024
Register of provisions
n. 134 of March 7, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, Members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament
and of the Council of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC, General Data Protection Regulation (hereinafter, Regulation);

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing
the Code regarding the protection of personal data
(hereinafter, Code);

HAVING REGARD to Regulation No. 1/2019 concerning
internal procedures with external relevance,
aimed at carrying out the tasks and
exercising the powers entrusted to the Guarantor for the
protection of personal data, approved by
Resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019 and on www.garanteprivacy.it,
doc. web n. 9107633 (hereinafter "Guarantor Reg. No.
1/2019");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Secretary
General pursuant to Article 15 of Guarantor Reg.
No. 1/2000 on the organization and functioning
of the office of the Guarantor for the protection of personal data
(doc. web n. 1098801);

REPORTING Prof. Pasquale Stanzione;

WHEREAS

1. The investigative activity

On XX, the General Director of the General Directorate
of Digitalization, Health Information System,
and Statistics of the Ministry of Health (hereinafter, Ministry) informed the Guarantor's Office, via email,
about the alleged
violation of the New Health Information System
(hereinafter "NSIS").

On the same date, the Office pointed out that "the facts
described constitute a violation of personal data
to be entered in the Ministry's register of violations – even if it only concerned the
"user access credentials to the NSIS systems", which
was "very likely that [the conditions for] notifying the Guarantor and for

communicating to the affected parties were met. These conditions must, of course, be assessed by the Ministry, which should have all the elements to make these assessments”, that “in cases like this, at least the number of affected parties and the characteristics of the authentication credentials must be considered” and, finally, that “the main risk arising from the theft of authentication credentials is indeed the use of the same for access to other online services, also provided by entities other than the holder who suffered the violation”.

Subsequently, in the month of XX, the Office learned from some news reports of a cyber attack on the system used by the Ministry for the authentication and authorization of NSIS users that would have occurred in the month of XX. In particular, according to reports from the press, third parties would have gained access to some personal data of affected individuals contained within the log files stored within the Ministry's IT systems.

Following these news reports and in light of the informal communication from the Ministry on XX, the Office requested information from the Ministry with notes dated XX (prot. n. XX) and XX (prot. n. XX) in

order to acquire elements regarding the scope of the personal data violation, the assessments made by the Ministry regarding the risks to the rights and freedoms of the affected parties that could arise, as well as the technical and organizational measures adopted to prevent unauthorized access to the NSIS following the illicit acquisition of some authentication credentials.

In response to these requests, the Ministry replied, respectively, with notes dated XX (prot. n. XX) and XX (prot. n. XX), stating that:

- “during the period from XX to XX

[...] it suffered a cyber attack aimed at the exfiltration of credentials for access to the systems related to the New Health Information System (NSIS)” of which it learned

“through a telematic communication (email) from a user [...] who reported having identified information pertaining to the Administration in an announcement on the dark web”;

- following this communication, and the subsequent related analyses, “it was possible to understand how the attacker was able to acquire credentials of users accessing the NSIS platform, reachable at the following address <https://nsis.sanita.it>, during the period from XX to XX” and “to confine the exfiltration of credentials to the time slots on September 7 of this year from 9:00 to 11:00 and on XX of this year from 10:00 to 11:00”;

- a total of 1,578 authentication credentials were compromised;

- it had “proceeded to identify all users who accessed [...] in the period” after “verifying that the email addresses of the affected users were attributable to the users themselves” and had forced the “reset of passwords, notifying the same users of this intervention for security reasons”. This procedure, carried out in phases,

prioritized “the accounts linked to nsis.sanita.it

during the potential data exfiltration time slots” had, therefore, led to the creation of “a new random password [...] with a mandatory change upon first access”;

- had “blocked the self-provisioning registration service that allowed a subject interested in using NSIS functionalities to create their own credentials independently, albeit with limited access to only the functionalities for managing their personal information and to the request for application profiles subject to subsequent precise approval by the application Administrators” and had “prepared a ‘Mitigation, Eradication and Improvement Plan’ [...] in order to contain the incident and avoid impacts in the future from the same type of threat”;

- had forced the “password reset, notifying the users of this intervention for security reasons” and had informed users “via email of ongoing security issues that required the password reset”;

- with reference to the notification of the breach to the Authority, had “assessed that no risks to the rights and freedoms of the affected parties arising from the incident had materialized” and had therefore not communicated the breach to the affected parties (see note of XX). Regarding the documentation on the personal data breach referred to in Article 33, paragraph 5, of the Regulation, the documents Executive and Technical Report JBoss Web Application Compromise, drafted by Leonardo Company S.p.A., and Report on the activities carried out for the password reset of NSIS accounts following the security incident drafted by Engineering S.p.A. were provided;

- concerning the exfiltration of credentials, it had been possible “following the tampering of the code of the page where users enter their credentials to access the NSIS platform in such a way as to redirect, in clear text, the same credentials also to a URL external to the Ministry’s perimeter,” and that this operation had been carried out “by compromising the vulnerable JBoss application server,” “facilitated by the exposure of a web page that allowed access to advanced configuration functionalities of the web application hosted by the system” and “traceable to known and easily accessible tutorials and exploits online.” The JBoss application server, in fact, presented “some misconfigurations that could have allowed the attacker to obtain administrative privileges on the machine without entering any password” and “execute commands with root privileges” (see Executive and Technical Report JBoss Web Application Compromise). Regarding this last aspect, with provision no. 88 of March 10, 2022 (web doc no. 9780717), the Authority had deemed that the aforementioned personal data breach was likely to present a high risk to the rights and freedoms of natural persons, a condition for which communication to the affected parties is required under Article 34, paragraph 1, of the Regulation.

In the aforementioned provision, it was deemed that the notice “via email of ongoing security issues that required the password reset” from the Ministry – although, initially, it could represent a sufficient measure to inform the affected parties about the initiatives undertaken immediately, also offering a dedicated contact point to which to turn – did not constitute an adequate tool for fulfilling the obligations under Article 34 of the Regulation, as it did not allow the affected parties to be effectively aware of the risks arising from the breach, also in order to enable them to take the necessary precautions such as, for example, not using the compromised password anymore, or at least a similar one, to access the NSIS platform or other online services.

This, in particular, considering the following elements:

- the processing carried out within the NSIS requires a high degree of accountability, in order to ensure trust among the affected parties, particularly satisfying the legitimate expectations of transparency and security of the processing;

- the severity and persistence of the possible consequences for natural persons arising from the compromise of authentication credentials, considering the habit of users to use very similar passwords, changing only some characters (for example, a number or a letter) and, in any case, to reuse the same password, even after some time, for the same or other online services;

- the possibility that the authentication credentials in question could be exploited to access the NSIS platform and consult or acquire personal data related both to the users to whom they are attributed (for

example, personal data of the personal profile) and to other categories of affected parties (for example, in the case of NSIS applications that involve the processing of personal data of beneficiaries of the national health service), as well as for further potential illegal activities.

In light of this, with the aforementioned provision, the Authority ordered the Ministry to immediately communicate the personal data breach in question to all affected parties, describing the nature of the breach and its possible consequences, providing them with the contact details of the Data Protection Officer or another specifically established contact point where they could obtain more information, as well as specific indications on the measures they can take to protect themselves from any negative consequences of the breach, such as not using the compromised password anymore, or otherwise similar, for access to the NSIS platform or other online services. Following the Authority's decision, the Ministry informed the interested parties involved in the personal data breach by sending an email to the affected individuals with the subject "NSIS user password update of the Ministry of Health – Further information and instructions," in which it informed that "the password update operation for the NSIS user – carried out and communicated via email last September with the subject 'NSIS user password update of the Ministry of Health [...]' was necessary following illicit activities that resulted in the compromise of the [...] authentication credentials for the NSIS platform of the Ministry of Health" and highlighted the risk that "the compromised credentials could be unlawfully exploited," emphasizing "the importance of not using the previous password prior to the update, or any similar one, for access to the NSIS platform or other online services."

2. The initiation of the procedure for the adoption of corrective and sanctioning measures, pursuant to Article 166, paragraph 5, of the Code

In relation to the checks carried out, based on the elements acquired and the facts emerged following the investigative activity, as well as subsequent evaluations, the Office, with note of XX (prot. n. XX), notified the Ministry of Health of the initiation of the procedure for the adoption of the corrective and sanctioning measures referred to in Article 58, paragraph 2, of the Regulation, having ascertained, in the case in question, the existence of violations of the relevant regulations regarding the protection of personal data.

With the same note, the violations committed (pursuant to Article 166, paragraph 5, of the Code) were notified to the aforementioned Ministry, inviting it to submit written defenses or documents and, if necessary, to request to be heard by this Authority, within a period of 30 days (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, of Law No. 689 of November 24, 1981).

Specifically, and as described below, it was ascertained that the processing of personal data concerning the matter in question was carried out:

- a) in a manner not compliant with the principles of "integrity and confidentiality," security of processing, and "data protection by default," in violation of Articles 5, paragraph 1, letter f), 32, and 25, paragraph 1, of the Regulation;
- b) in violation of the notification obligations under Article 33 of the Regulation and those of documentation under Article 33, paragraph 5 of the Regulation;
- c) in violation of the obligations of communication to the interested parties under Article 34 of the Regulation.

2.1. Notification of the personal data breach to the Authority

Taking into account what has been stated in the documents, it was ascertained that the access and exfiltration of personal data – including user authentication credentials – constitutes a personal data breach (cf. Article 4, point 12, of the Regulation) and, therefore, there are grounds for a violation of the obligations under Article 33 of the Regulation by the Ministry, not considering that the aforementioned informal communication of XX is suitable to constitute a notification of the personal data breach.

Furthermore, the elements of a violation of the obligations under Article 33, paragraph 5, of the Regulation were ascertained, as the documentation provided during the investigation was lacking essential information, such as the effects and possible consequences arising from the breach,

considering that the documentation provided does not contain the outcomes of the risk assessment for the rights and freedoms of the interested parties, arising from the breach as an essential element to determine the necessity of notifying the supervisory authority and communicating to the interested parties.

2.2. Communication of the personal data breach to the interested parties

In light of the above, a violation of Article 34 of the Regulation by the Ministry was ascertained, considering that the Ministry communicated about the personal data breach that occurred to the affected individuals only following the aforementioned decision of the Authority No. 88 of March 10, 2022.

2.3. Security of processing: the failure to adopt adequate measures to detect personal data breaches, inadequate configuration, and vulnerability of processing systems

From the documentation in the records, it emerged that the Ministry learned of the breach on XX "through an electronic communication (email) from a user [...] who reported having identified information pertaining to the Administration during the period between XX and XX."

In light of the elements gathered during the investigation, it is noted that the failure to adopt adequate measures to detect and manage personal data breaches in a timely manner does not comply with the provisions of Articles 5, paragraph 1, letter f), and 32, paragraph 1, of the Regulation, which, in this case, requires the data controller to implement measures to "ensure on a continuous basis the confidentiality, integrity, availability, and resilience of processing systems and services" (letter b)). This also specifically refers to the procedure for testing, verifying, and regularly evaluating the effectiveness of technical and organizational measures in order to ensure...

****the security of processing.****

2.4 Data protection by design

In light of what is indicated by Article 25 of the Regulation and the Guidelines 4/2019 on Article 25: data protection by design and by default (adopted by the European Data Protection Board (hereinafter, Board) on XX; see in particular points 84 and 85), a violation of the principle of data protection by design has been established on the part of the Ministry.

3. The defensive writings

By note dated XX (prot. n XX), the Ministry of Health submitted its defensive writings, generally stating that:

- in response to the email of XX, the Office of the Guarantor "highlighted that the personal data breach should be entered in the register of breaches and referred to the Ministry of Health the appropriate assessments regarding the need to notify the breach to the Guarantor Authority for the protection of personal data, summarizing in general the elements to be considered for such assessment 'at least the number of affected individuals and the characteristics of the authentication credentials must be considered (is the username easily traceable to a specific individual? was the password chosen by the user or automatically generated by the system?). The main risk arising from the theft of authentication credentials is indeed their use for accessing other online services, even provided by entities other than the holder who suffered the breach)" (p. 2);
- with the communication of XX, "it represented that it had not notified the breach as, after making the appropriate assessments, it deemed it concretely unlikely that the breach posed a risk to the rights and freedoms of the affected users, providing, in support of its claims, attached technical documentation on: the rules for password generation in NSIS; the document related to the incident 'Executive and Technical Report JBoss Web Application Compromise', prepared by Leonardo Company S.p.A.; the document 'Report on the activities carried out for the password reset of NSIS accounts following the security incident' prepared by Engineering S.p.A." (p. 2);
- with the subsequent communication of XX, "it represented that it had preliminarily verified that the email addresses of the affected users were attributable to them, then it had notified them via email of ongoing security issues that required a password reset. In the same email, the references of the Service Desk were indicated for any information and clarifications, and at the same time the Ministry of Health had begun the password reset process, setting new random passwords automatically

generated by the system and requiring a change upon first access, in addition to blocking the self-provisioning registration service that allowed an individual interested in using NSIS functionalities to create their own credentials independently, albeit with limited access only to the functionalities for managing their personal information, without further authorizations for access to other functionalities managed by the Ministry of Health" (p. 2);

- following the Guarantor's provision no. 88 of March 10, 2022, "it provided a prompt response via certified email on XX, sending the text of the communication made to the affected individuals on XX" (p. 3).

With reference, moreover, to the specific observations raised by the Office, relating to compliance with the regulations on the protection of personal data, the Ministry noted the following.

a) On the violation of the principles of integrity and confidentiality, security of processing, and data protection by default (Articles 5, par. 1, lett. f), 32, and 25, par. 1, of the Regulation):

- "the NSIS user authentication portal manages access through an Identity Management system structured for the secure management of passwords and user work sessions that does not allow the storage of passwords in clear text, nor any potential storage in log files, in adherence to good security practices and protection of user data" (p. 3);

- "this Ministry, also at the time of signing the current agreement with INAIL for the management of the infrastructure used for NSIS, has provided stringent security measures described in the appointment of said Institute as data processor, [...] with the specific aim of preventing any breaches of personal data processed" (p. 3);

- "the act of exfiltration of access credentials to NSIS was promptly contained within the time slots of XX, from 9:00 to 11:00, and of XX, from 10:00 to 11:00, and immediately thereafter activities began on the analysis of the incident and execution of remedial actions aimed at containing and recovering the impacted systems. The Ministry of Health, in fact, immediately implemented measures to detect and manage the breach, verified its causes, the affected individuals, and any risk to the rights and freedoms of the latter, intervening immediately to adjust its security measures, so that the event could not recur" (pp. 3 and 4);

- "the above interventions, including those of the comprehensive update of the authentication and authorization system for NSIS, subject to the attack, which began before the act of exfiltration in question and was definitively completed on XX, have undoubtedly helped to improve the...

****Security Characteristics of the System**** (p. 4).

b) On the violation of notification obligations under Article 33 of the Regulation and those of documentation under Article 33, paragraph 5 of the Regulation:

- "The Ministry of Health, upon becoming aware of the incident, conducted the appropriate investigations and adopted the necessary measures to remedy the situation, communicated the incident to the competent office of this Authority via email on XX, indicating, albeit informally, all the elements required for the notification of a data breach, as per Article 33, paragraph 3 of Regulation (EU) 2016/679, namely: the nature of the alleged breach and the reasons underlying it "the presence of malicious code on an internal 'Jboss' server aimed at intercepting and communicating external user access credentials to the NSIS systems, which was active for a total of 3 hours on September 7 and 8"; its probable consequences "At present, there is no proven evidence of exfiltrated data, however, verification activities on the systems are ongoing"; the measures currently implemented to remedy the breach "The aforementioned code has been promptly removed and potentially compromised credentials have been reset. A series of actions aimed at assessing any further vulnerabilities and strengthening defenses have also been undertaken and are ongoing" (p. 4);

- "Upon receiving the above feedback from the aforementioned office, after further careful evaluation, in accordance with Article 33 of Regulation (EU) 2016/679 and the guidelines on the notification of personal data breaches, the Ministry deemed it unnecessary to proceed with the formal notification of a personal data breach, as it was not likely that risks to the rights and freedoms of the data subjects would materialize, considering the following elements: • absence of personal data in the potentially exfiltrated credentials, both in the 'user name' component (composed of the letters 'mi' and a numerical sequence assigned by the System), and in the 'password' component, which is subject to composition rules set by the System, preventing the inclusion of personal data; • established practices by digital

service providers of 'security awareness' actions towards their users with suggestions and advice on 'cyber hygiene', including the need to diversify their passwords. For the aforementioned reasons, confirming the risk assessments conducted, considering that the vulnerabilities that caused the intrusion were immediately removed and the access credentials subject to exfiltration were promptly reset, preventing any potential use by unauthorized individuals, as of the date of this document and nearly a year after the incident occurred, there has been no evidence of any kind regarding the sale, exfiltration, or unlawful use of data potentially originating from the NSIS systems and attributable to the unlawful use of the aforementioned credentials. Therefore, the breach does not appear to have posed concrete risks to the rights and freedoms of natural persons" (pp. 4 and 5);

- Based on the criteria indicated by the Guidelines on the notification of personal data breaches pursuant to Regulation (EU) 2016/679 in effect at the time of the events (adopted by the Article 29 Working Party on October 3, 2017, as amended and last adopted on February 6, 2018, and endorsed by the Committee – hereinafter, "Guidelines on Notification" – subsequently updated with the Guidelines 9/2022 on personal data breach notification under GDPR (adopted by the Committee on March 28, 2023), it was deemed that: "the breach in question did not result in the loss or destruction of particular or highly sensitive personal data"; "the breach involved a limited number of data not falling within the category of sensitive data, but only related to usernames (default preset and not containing personal data) and passwords (subject to technical rules that do not allow the use of personal data)"; consequently, "the holders of the compromised accounts cannot be directly identified"; "the event does not appear to have resulted in harmful consequences for the affected individuals"; "the individuals affected by the breach were not directly identifiable and do not fall into particular categories"; "despite the Ministry of Health primarily handling sensitive data, the data subject to the breach do not fall within this category, therefore this aspect cannot be considered relevant in the risk assessment in this case"; "considering the high number of accounts present in NSIS compared to the number of users involved, the impact was not deemed significant" (p. 5);

- Wanting to "take Case No. 6, relating to the exfiltration of passwords from a website, as a reference, a case entirely similar to the one under discussion, [...] it is highlighted that in these cases "notification was not mandatory, but in many cases it can be considered a good practice. The data controller should correct the vulnerability and adopt new security measures to prevent similar data breaches in the future, such as systematic security checks of the website. The breach should be documented pursuant to Article 33, paragraph 5, but no notification or communication is necessary." As stated above and as will be mentioned later, this Ministry has implemented the actions required in the guidelines; therefore, considering that the aforementioned Article 33 leaves the data controller a margin of discretion in assessing the necessity of sending the breach notification to the supervisory authority and, according to the assessments conducted as described above, the undersigned has not...

Necessary to proceed with notification, given the improbability of risks to the rights and freedoms of individuals, and considering, moreover, the informal communication with which the competent office of this Authority was informed of the incident, it is believed that the conduct of this Ministry has not, in substance, violated the current regulations and, in particular, Article 33 of Regulation (EU) 2016/679 (p. 6);

- ***"Furthermore, regarding the contested violation of the obligations under Article 33, paragraph 5 of Regulation (EU) 2016/679, [...] Having collected all necessary documentation to be kept in the register of violations, this Ministry opened on XX a specific register in its DOCSPA electronic protocol, related to the attack on the NSIS, [...] where not only are all documents related to the violation contained, [...] but the information concerning the description, date/period of the incident, nature of the incident, type of incident, description of the incident, cause of the incident, estimated severity of the incident, systems and infrastructures involved, security measures taken/to be taken, category of data subjects, number of data subjects is detailed; "All other information, such as the effects and consequences of the violation for the data subjects, as well as the risk assessment arising from the violation, are all contained in the responses provided respectively on the dates XX, XX, and XX"*** (pp. 6 and 7).

c) **On the violation of communication obligations towards the data subjects under Article 34 of the Regulation.**

- ***“The Ministry of Health, having become aware of the attack on the NSIS, promptly reset the compromised passwords and sent the affected users an email containing a warning message [...] clearly stating the need to update the password for access to the NSIS platform for security reasons, as well as the toll-free number of the technical service desk to contact for information and further clarifications”** (p. 7);
- ***“The communication is not considered mandatory, as ‘this case does not present risks to the rights and freedoms of the data subjects.’ Moreover, in this case, this Ministry promptly took action to remedy the violation, ordering the reset of passwords and informing the users affected by the violation of the need to change the previously compromised password, achieving the objective, inherent to communication, of mitigating the risks arising from the violation”** (pp. 7 and 8);
- ***“In addition to the evaluations mentioned above regarding the absence of ‘a high risk to the rights and freedoms of individuals’ in this specific case, it is highlighted that communication to the data subjects was not necessary as, according to what is provided in paragraph 3, letter b) ‘the data controller subsequently adopted measures to avert the occurrence of a high risk to the rights and freedoms of the data subjects’”** (p. 8);
- ***“For all the reasons stated above, the first email sent to the data subjects, containing the notice regarding the password change, can be considered sufficient for the purposes of risk minimization pursued by the regulations regarding the communication of a personal data breach to the data subject, as per Article 34 of Regulation (EU) 2016/679”** (p. 9).

4. The regulations on personal data protection

With particular reference to the matter at hand, it is emphasized that personal data must be “processed in a manner that ensures adequate security [...] including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage” (principle of integrity and confidentiality) (Article 5, paragraph 1, letter f, of the Regulation).

Article 33 of the Regulation establishes that “in the event of a personal data breach, the data controller shall notify the supervisory authority [...] without undue delay and, where feasible, within 72 hours of becoming aware of it, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons” (paragraph 1).

In this regard, recitals 75 and 76 of the Regulation establish that, as a rule, both the likelihood and the severity of risks to the rights and freedoms of data subjects should be taken into account in the risk assessment, and that such risks should be determined based on an objective assessment.

The aforementioned Article 33 of the Regulation also provides that “the data controller documents any personal data breach, including the circumstances surrounding it, its consequences, and the measures taken to remedy it” (paragraph 5).

Regarding the documentation of the breach, the Guidelines on notification in effect at the time of the events – later updated with the Guidelines 9/2022 on personal data breach notification under GDPR of March 28, 2023 – establish that “regardless of whether a breach must or must not be notified to the supervisory authority, the data controller must keep documentation of all breaches,” which “this obligation is linked to the principle of accountability,” as per Article 5, paragraph 2, and that “the purpose of maintaining records of non-notifiable breaches, in addition to those that are notifiable, is also linked to the obligations of the data controller under Article 24, and the supervisory authority may request to consult such records. Consequently, the data controller is encouraged to create a register.” internal violations, regardless of whether the notification is required or not.”

Furthermore, the same Notification Guidelines specify that “although it is the responsibility of the data controller to determine which method and structure to use to document a breach, certain key information

should always be included," that the data controller is required to "record details relating to the breach, including the causes, facts, and personal data involved. It should also indicate the effects and consequences of the breach and the measures taken to remedy it" and recommend "to also document the reasoning behind the decisions made in response to a breach. In particular, if a breach is not notified, it is appropriate to document a justification for that decision. The justification should include the reasons why the data controller believes it is unlikely that the breach poses a risk to the rights and freedoms of individuals. Alternatively, if it believes that one of the conditions set out in Article 34, paragraph 3, is met, the data controller should be able to provide adequate evidence of the circumstances that apply in the specific case. If the data controller notifies a breach to the supervisory authority, but the notification is delayed, the data controller must be able to provide the reasons for the delay; documentation regarding this circumstance could help demonstrate that the delay in reporting is justified and not excessive" (section V.A).

The Guidelines 01/2021 on Examples regarding Data Breach Notification (adopted by the Committee on December 14, 2021 – hereinafter Guidelines on cases of personal data breaches), referring to the Notification Guidelines, specify that "the internal documentation of a breach is an obligation independent of the risks associated with the breach itself and must be prepared in each individual case" (par. 15).

Article 34 of the Regulation states that "when a personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall communicate the breach to the data subject without undue delay" (par. 1) and that "the communication to the data subject referred to in paragraph 1 of this article describes in clear and plain language the nature of the personal data breach and contains at least the information and measures referred to in Article 33, paragraph 3, letters b), c) and d)" (par. 2). Furthermore, recitals 75 and 76 of the Regulation state that, in general, both the likelihood and the severity of the risks to the rights and freedoms of data subjects should be considered in the risk assessment and that such risks should be determined based on an objective assessment.

The aforementioned Article 34 of the Regulation also provides that "communication to the data subject referred to in paragraph 1 is not required if one of the following conditions is met: a) the data controller has implemented appropriate technical and organizational measures to protect and such measures were applied to the personal data concerned in the breach, in particular those intended to make the personal data unintelligible to anyone not authorized to access it, such as encryption; b) the data

controller has subsequently taken measures to mitigate the high risk to the rights and freedoms of data subjects referred to in paragraph 1; c) such communication would require disproportionate effort. In such cases, a public communication or a similar measure is instead taken, by which data subjects are informed with similar effectiveness" (par. 3).

In this regard, the Notification Guidelines identify the factors to consider – in the event of a personal data breach – in assessing the risk to the rights and freedoms of data subjects: the type of breach; the nature, sensitive character, and volume of personal data; the ease of identifying data subjects; the severity of the consequences for data subjects; the particular characteristics of the data subject; the particular characteristics of the data controller; as well as the number of data subjects involved and also highlight that "the regulation states that the communication of a breach to data subjects should occur 'without undue delay,' which means as soon as possible," considering that the main objective of the communication to data subjects is to provide them with specific information about the measures they can take to protect themselves. The same Guidelines indeed provide that the data controller, among the measures to be taken to address the breach and mitigate its possible negative effects on data subjects, "should also provide specific advice to individuals on how to protect themselves from the possible negative consequences of the breach."

The Guidelines on cases of personal data breaches note that communication to data subjects is a good practice and a mitigating factor in the presence of an exfiltration of authentication credentials and, therefore, recommend communicating personal data breaches involving credentials in any case, even if passwords are protected with cryptographic algorithms (cf. pars. 59 and 62). In the case of exfiltration of clear-text passwords, they further emphasize that notification to the Supervisory Authority and communication to data subjects cannot be considered optional (cf. par. 68).

****Communication to the Data Subjects****

The communication to the data subjects represents, moreover, one of the measures that the data controller can adopt to mitigate the possible negative effects of a personal data breach for the data subjects and has as its main objective the provision of specific information on the measures that the data subjects themselves can take to protect themselves from the possible negative consequences of a breach (cf. recital 86 of the Regulation).

****Article 32 of the Regulation****, concerning the security of processing, establishes that "taking into account the state of the art and the costs of implementation, as well as the nature, scope, context, and purposes of the processing, and the risk of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk" (par. 1) and that "in assessing the appropriate level of security, particular consideration shall be given to the risks

presented by the processing which are caused in particular by the destruction, loss, alteration, unauthorized disclosure of, or access, whether accidental or unlawful, to personal data transmitted, stored, or otherwise processed” (par. 2).

The aforementioned Guidelines on Notification clarify, furthermore, that “the ability to identify, manage, and report a breach in a timely manner should be considered an essential aspect” of the technical and organizational measures that the data controller and the processor must implement, pursuant to Article 32 of the Regulation, to ensure an adequate level of security of personal data.

Based on the principle of data protection by design (Article 25, par. 1, of the Regulation), the data controller is then required to implement the principles of data protection (Article 5 of the Regulation) by adopting appropriate technical and organizational measures and integrating the necessary safeguards into the processing to meet the requirements of the Regulation and protect the rights and freedoms of the data subjects. The obligation to maintain, verify, and update, where necessary, the processing also applies to pre-existing systems. This implies that systems designed before the entry into force of the Regulation must be subjected to checks and maintenance to ensure the application of measures and safeguards that effectively implement the principles and rights of the data subjects.

With reference to the cited principle of integrity and confidentiality (Article 5, par. 1, lett. f), of the Regulation), the controller must continuously assess whether it is using, at any given time, the appropriate means of processing and whether the measures adopted effectively counteract existing vulnerabilities (cf. Guidelines 4/2019 on Article 25 – hereinafter, “Guidelines on Article 25” – specifically points 84 and 85).

In particular, the controller must:

- assess the risks to the security of personal data, considering the impact on the rights and freedoms of the data subjects, and effectively counter those identified;
- carry out periodic reviews of the security measures in place to safeguard personal data;
- take security requirements into account as soon as possible in the design and development of the system, integrating and continuously conducting relevant testing;
- protect personal data from unauthorized and accidental alterations and access, both during their transfer and during their storage;
- have adequate procedures in place to manage personal data breaches, including procedures for their documentation and communication to the affected data subjects.

****5. Outcome of the Investigation****

In general terms, the arguments put forward in the defense writings, although worthy of consideration, do not allow for overcoming the observations notified by the Office with the initiation of the procedure and are insufficient to allow for the archiving of the present procedure, as none of the cases provided for by Article 11 of the Garante Regulation No. 1/2019 apply.

With reference to the specific observations made in the initiation of the procedure aimed at adopting corrective and sanctioning measures, in relation to what has been argued by the Ministry, the following is noted.

a) On the violation of the principles of integrity and confidentiality, security of processing, and data protection by default (Articles 5, par. 1, lett. f), 32, and 25, par. 1, of the Regulation):

- The Ministry of Health is responsible for the management of personal data processing carried out within the NSIS, which constitutes the “reference tool for the quality, efficiency, and appropriateness measures of the National Health Service (SSN), through the availability of information that, for completeness, consistency, and timeliness, supports the Regions and the Ministry in the exercise of their functions and, in particular, the Ministry in its role as guarantor of the uniform application of the Essential Levels of Care (LEA) throughout the national territory” (cf. what is reported on the official website of this Ministry, https://www.salute.gov.it/portale/temi/p2_6.jsp?lingua=italiano&id;=2978&area;=sistemaInformativo&menu;=prese).

This therefore requires, in implementation of the principle of accountability (Articles 5, par. 2, and 24 of

the Regulation), high standards of capability in identifying the necessary measures to ensure adequate security of processing, also considering the legitimate expectations of the...

the necessity of notification to the Authority, as well as the measures taken to address the incident and prevent future occurrences;

- furthermore, it should be noted that the documentation provided did not adequately reflect the principle of accountability, as it lacked a comprehensive analysis of the incident, including the identification of the affected data subjects and the nature of the personal data involved.

c) On the violation of the obligations regarding data protection impact assessments (DPIAs) as per Article 35 of the Regulation:

- it has been established that the Ministry did not carry out a DPIA prior to the processing activities that led to the data breach, despite the fact that the processing involved sensitive data related to health, which is classified as high risk under the Regulation;

- the absence of a DPIA indicates a failure to assess and mitigate risks associated with the processing of personal data, which is a fundamental requirement under the Regulation to ensure compliance with data protection principles and to safeguard the rights of data subjects.

d) On the violation of the principle of accountability as per Article 5(2) of the Regulation:

- the Ministry has not demonstrated compliance with the principle of accountability, as it has failed to implement appropriate technical and organizational measures to ensure and be able to demonstrate that the processing of personal data is performed in accordance with the Regulation;

- this lack of accountability is further evidenced by the inadequate response to the data breach, including the failure to notify the relevant authorities and affected individuals in a timely manner, as well as the insufficient measures taken to prevent similar incidents in the future.

In conclusion, the findings indicate multiple violations of the GDPR by the Ministry, particularly concerning the protection of personal data, the notification of data breaches, the documentation of incidents, the conduct of DPIAs, and the overall principle of accountability. These violations not only compromise the rights and freedoms of data subjects but also undermine the integrity of the data protection framework established by the Regulation.

the necessity to notify the supervisory authority and to communicate to the interested parties.

Moreover, this is without taking into account what is indicated in the "Guidelines on Notification," where it is recommended to document the reasoning behind the decisions made and the reasons justifying the decision not to notify the violation;

- furthermore, it is believed that providing the Authority, during a specific investigation, with elements related to the violation of personal data does not satisfy the obligation of documentation provided for in Article 33, paragraph 5, of the Regulation, as these are different obligations aimed at equally different purposes (in one case, the exercise of supervisory activity by the Authority, in the other case the obligation of the data controller to ensure compliance with the Regulation in terms of accountability).

c) On the violation of the communication obligations towards the interested parties referred to in Article 34 of the Regulation:

- the reasons that compelled the Ministry to notify the Guarantor, already expressed in the previous point b), are nonetheless valid also with reference to the obligation that the same Ministry adequately communicate the violation to the interested parties pursuant to Article 34 of the Regulation, considering that the incident was certainly likely to present a high risk to the rights and freedoms of natural persons;

- the inadequacy of the first communication sent by the Ministry is confirmed by the fact that, in light of this, the Guarantor deemed it necessary to order the Ministry, with provision no. 88 of March 10, 2022 (not subject to specific challenge), to fulfill the obligation referred to in Article 34, paragraph 1, of the Regulation. In fact, the Guarantor considered that the email notice of ongoing security issues requiring the reset of the password by the Ministry – although, at first, it could have represented a sufficient measure to inform the interested parties about the initiatives taken immediately, also offering a dedicated contact to reach out to – did not constitute an adequate tool for fulfilling the obligations

referred to in Article 34 of the Regulation, as it did not allow the interested parties to be effectively aware of the risks arising from the violation, also in order to enable them to take the necessary precautions such as, for example, not using the compromised password anymore, or any similar one, for access to the NSIS platform or other online services;

- the exemption from the obligation referred to in paragraph 3, letter b), of the aforementioned Article 34 of the Regulation cannot be invoked either, as the measures indicated in the first communication sent to the interested parties cannot be considered adequate to avert the emergence of a high risk to the rights and freedoms of the interested parties, such as in the case of an unaware password change that is likely very similar to the exfiltrated one. The risk remains high due to the fact that there is no evidence, from the data controller, of password management policies that provide for the retention of password history or rules that prevent the reusability of passwords.

6. Conclusions

In light of the complex evaluations mentioned above, the statements made by the data controller in the defense writings, although deserving of consideration for the assessment of conduct, do not allow for overcoming the main objections notified by the Office with the initiation act for the adoption of the measures referred to in Article 58, paragraph 2, of the Regulation and are insufficient to allow for the closure of the present proceeding, as none of the cases provided for in Article 11 of the Guarantor Regulation no. 1/2019 apply.

In this context, confirming the objections notified by the Office with the note of XX (prot. no. XX), it is noted that, in the case at hand, the Ministry has committed the violation of:

a) principles of "integrity and confidentiality," security of processing, and "data protection by default," referred to in Articles 5, paragraph 1, letter f), 32, and 25, paragraph 1, of the Regulation;

b) notification obligations referred to in Article 33 of the Regulation and documentation obligations referred to in Article 33, paragraph 5 of the Regulation, as well as communication obligations towards the interested parties referred to in Article 34 of the Regulation.

In this context, considering that measures have been adopted to overcome the aforementioned criticalities, the conditions for the adoption of corrective measures referred to in Article 58, paragraph 2, of the Regulation do not exist.

7. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i), and 83 of the Regulation; Article 166, paragraph 7, of the Code).

The Guarantor, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] corrective measures [referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case," and, in this context, "the College [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website. pursuant to Article 166, paragraph 7, of the Code"

(Article 16, paragraph 1, of the Garante Regulation No. 1/2019).

In this case, the Ministry of Health has engaged in two distinct conducts, which must therefore be considered separately for the purpose of quantifying the administrative sanctions to be applied.

The aforementioned monetary administrative sanctions imposed, depending on the circumstances of each individual case, must be determined in amount taking into due account the elements provided for by Article 83, paragraph 2, of the Regulation.

7.1. In this regard, taking into account Article 83, paragraph 3, of the Regulation, in this case, the violation of the provisions cited in paragraph 6, letter a), of this provision (Articles 5, paragraph 1, letter f), 25, paragraph 1, and 32 of the Regulation) is subject to the application of the monetary administrative sanction provided for by Article 83, paragraph 5, of the Regulation.

With specific regard to the nature and severity of the violations, as well as the degree of responsibility

of the controller (Article 83, paragraph 2, letters a) and d), of the Regulation), it must be considered that the Ministry was not able to independently detect the violation of personal data that occurred through its own systems, but was informed of it thanks to a user report.

In light of these circumstances, it is believed that, in this case, the level of severity of the violations committed by the data controller is medium (Guidelines 04/2022 on the calculation of administrative fines under the GDPR, adopted by the Committee on May 23, 2023, point 60).

In a favorable sense to the controller, it must still be considered, pursuant to Article 83, paragraph 2, letters c), e) and f), of the Regulation, that the Ministry – for which no previous relevant violations have been reported – has nonetheless implemented measures to mitigate the damage suffered by the data subjects and has cooperated with the Authority during the investigation to remedy the violation and mitigate its possible negative effects; moreover, it should be added that, based on what was highlighted by the Ministry, “there has been no evidence of any kind regarding the sale, exfiltration, or illegal use of data potentially coming from the NSIS systems and attributable to the unlawful use of the aforementioned credentials” (assessment pursuant to Article 83, paragraph 2, letter k), of the Regulation).

In light of the aforementioned elements, assessed in their entirety, it is believed that the amount of the monetary sanction should be determined at the sum of €50,000 (fifty thousand) for the violation of Articles 5, paragraph 1, letter f), 25, paragraph 1, and 32 of the Regulation, as a monetary administrative sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

7.2. Also taking into account Article 83, paragraph 3, of the Regulation, in this case, the violation of the provisions cited in paragraph 6, letter b), of this provision (Articles 33 and 34 of the Regulation) is subject to the application of the monetary administrative sanction provided for by Article 83, paragraph 4, of the Regulation.

With specific regard to the nature and severity of the violations, as well as the degree of responsibility of the controller (Article 83, paragraph 2, letter a), of the Regulation), it must be considered that the Ministry did not adequately manage, also considering its role and the relevance of the NSIS within the National Health Service, the violation of personal data that occurred.

In light of these circumstances, it is believed that, in this case, the level of severity of the violations committed by the data controller is high (cf. the aforementioned Guidelines 04/2022 on the calculation of administrative fines under the GDPR).

Additionally, pursuant to Article 83, paragraph 2, letters h) and i), of the Regulation, it should be noted that the Ministry, even following discussions with the Authority, did not consider it necessary to notify the Authority of the violation of personal data pursuant to Article 33 of the Regulation, and that the communication to the data subjects, pursuant to Article 34 of the same Regulation, was made only following the adoption of a specific corrective measure by the Garante.

In a favorable sense to the controller, it must still be considered, pursuant to Article 83, paragraph 2, letters e) and f), of the Regulation, that the Ministry – for which no previous relevant violations have been reported – has cooperated with the Authority during the investigation to remedy the violation and mitigate its possible negative effects; moreover, it should be added that, based on what was highlighted by the Ministry, “there has been no evidence of any kind regarding the sale, exfiltration, or illegal use of data potentially coming from the NSIS systems and attributable to the unlawful use of the aforementioned credentials” (assessment pursuant to Article 83, paragraph 2, letter k), of the Regulation).

In light of the aforementioned elements, assessed in their entirety, it is believed that the amount of the monetary sanction should be determined at the sum of €50,000 (fifty thousand) for the violation of Articles 33 and 34 of the Regulation, as a monetary administrative sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

7.3. Based on what has been evaluated in the previous paragraphs 7.1 and 7.2 of this provision, it is believed that the total amount of the monetary sanction imposed on the Ministry of Health should be determined at the sum of €100,000 (one hundred thousand) in relation to the totality of the previously described violations.

Considering that the violations committed are of significant severity, also considering the risks to the rights and freedoms of the interested parties (potentially including the beneficiaries of the National Health Service), it is also deemed necessary to apply the accessory sanction of publication on the website of the Authority of this provision, as provided for by Article 166, paragraph 7, of the Code and by Article 16 of the Authority's Regulation No. 1/2019.

It is finally noted that the conditions set forth in Article 17 of the Authority's Regulation No. 1/2019 are met.

ALL OF THE ABOVE CONSIDERED, THE AUTHORITY

having noted the unlawfulness of the conduct carried out by the Ministry, described in the terms outlined in the reasoning, consisting of the violation of Articles 5, paragraph 1, letter f), 25, paragraph 1, 32, 33, and 34 of the Regulation;

ORDERS

the Ministry of Health, represented by the legal representative pro tempore, with its registered office at Viale Giorgio Ribotta 5, 00144 Rome (RM), Tax Code 80242250589, to pay the sum of €100,000 (one hundred thousand) as an administrative pecuniary sanction for the violations indicated in the reasoning. It is noted that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction;

ENJOINS

the aforementioned Ministry, in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €100,000 (one hundred thousand) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with Article 27 of Law 689/1981;

DISPOSES

pursuant to Article 166, paragraph 7, of the Code, the publication of this provision on the website of the Authority, considering that the conditions set forth in Article 17 of the Authority's Regulation No. 1/2019 are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150 of September 1, 2011, it is possible to appeal this provision before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, March 7, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Stanzione

THE SECRETARY GENERAL

Mattei